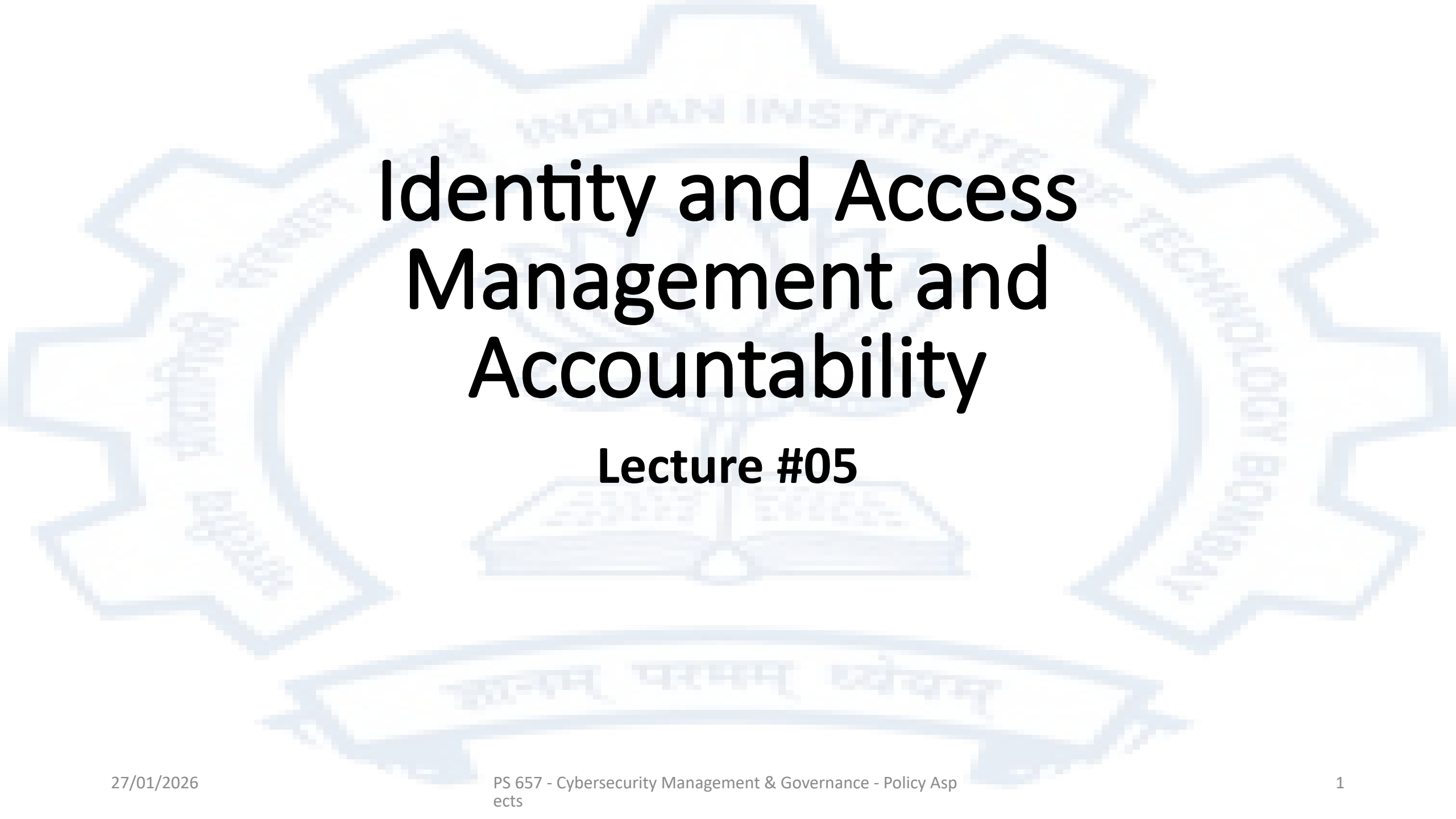




Identity and Access Management and Accountability

Lecture #05

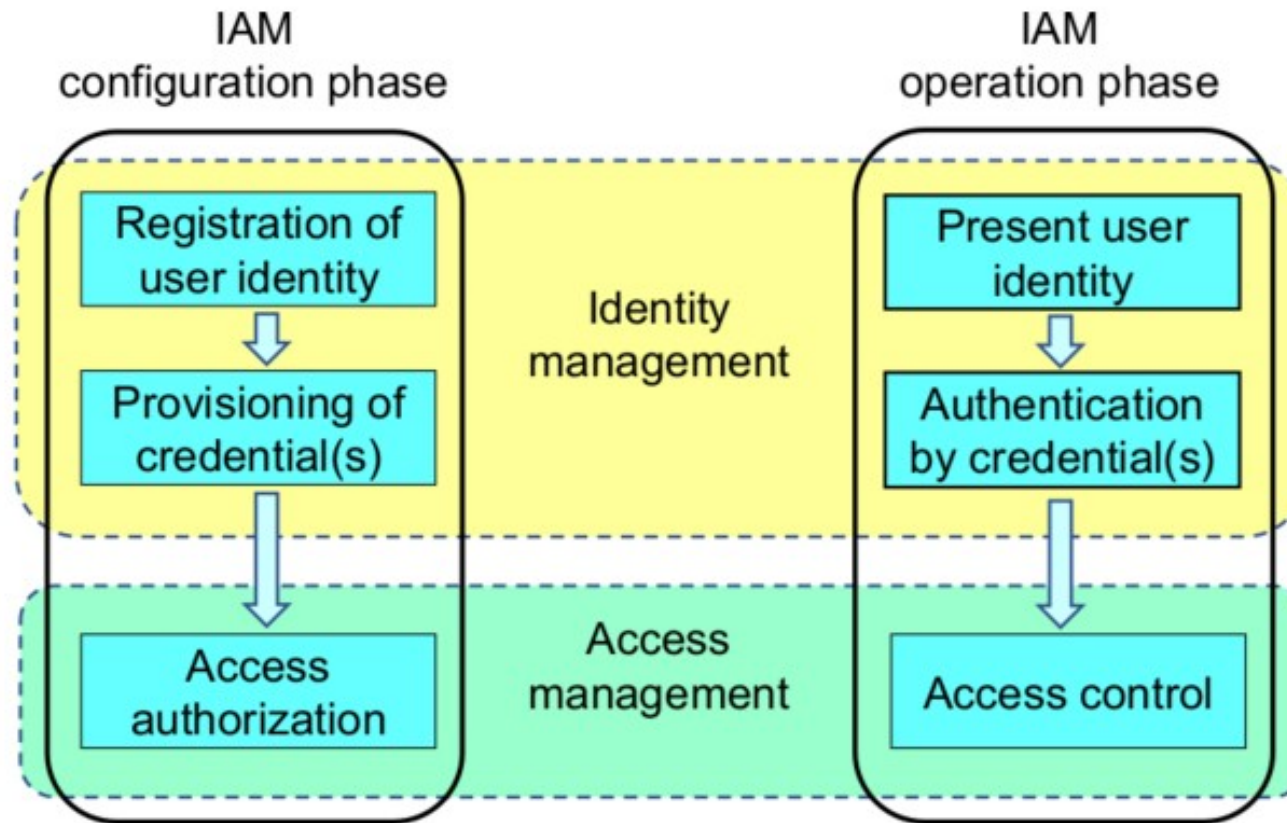
Identity Management Definition

- Broadly refers to the administration of individual identities within a system, such as a company, a network or even a country. In enterprise IT, identity management is about establishing and managing the roles and access privileges of individual network users. – NIST (Tech Standards Organization)
- Identity and access management (IAM or IdAM) or Identity management (IdM), is a framework of policies and technologies to ensure that the right users (that are part of the ecosystem connected to or within an enterprise) have the appropriate access to technology resources. – Wikipedia (Encyclopedia)
- Identity and Access Management (IAM) is a security and business discipline that includes multiple technologies and business processes to help the right people or machines to access the right assets at the right time for the right reasons, while keeping unauthorized access and fraud at bay. – Gartner (Consulting Firm)
- Identity management (IDM) is the process of managing digital identities within an organization. As the first piece of the broader field of Identity and Access Management (IAM), identity management is focused on identifying human and machine identities, prior to their gaining access to relevant organizational resources. – Saviynt (Product Producer)

Access Management Definitions

- Access Management is the set of practices that enables only those permitted the ability to perform an action on a particular resource. The three most common Access Management services you encounter every day perhaps without realizing it are: Policy Administration, Authentication, and Authorization. – NIST (Tech Standards Organization)
- Access management is the process of managing, controlling, and monitoring the access of users (human and non-human like service accounts) to organizations' IT resources (SaaS apps, data, network, and system), both in the cloud and on-premises. The ultimate goal of this management process is to ensure that only authorized users have the right access to the resources they need and to restrict unauthorized users' access. Zluri (Product Producer)

The Relationship of Identity and Access Management



https://en.wikipedia.org/wiki/Identity_and_access_management

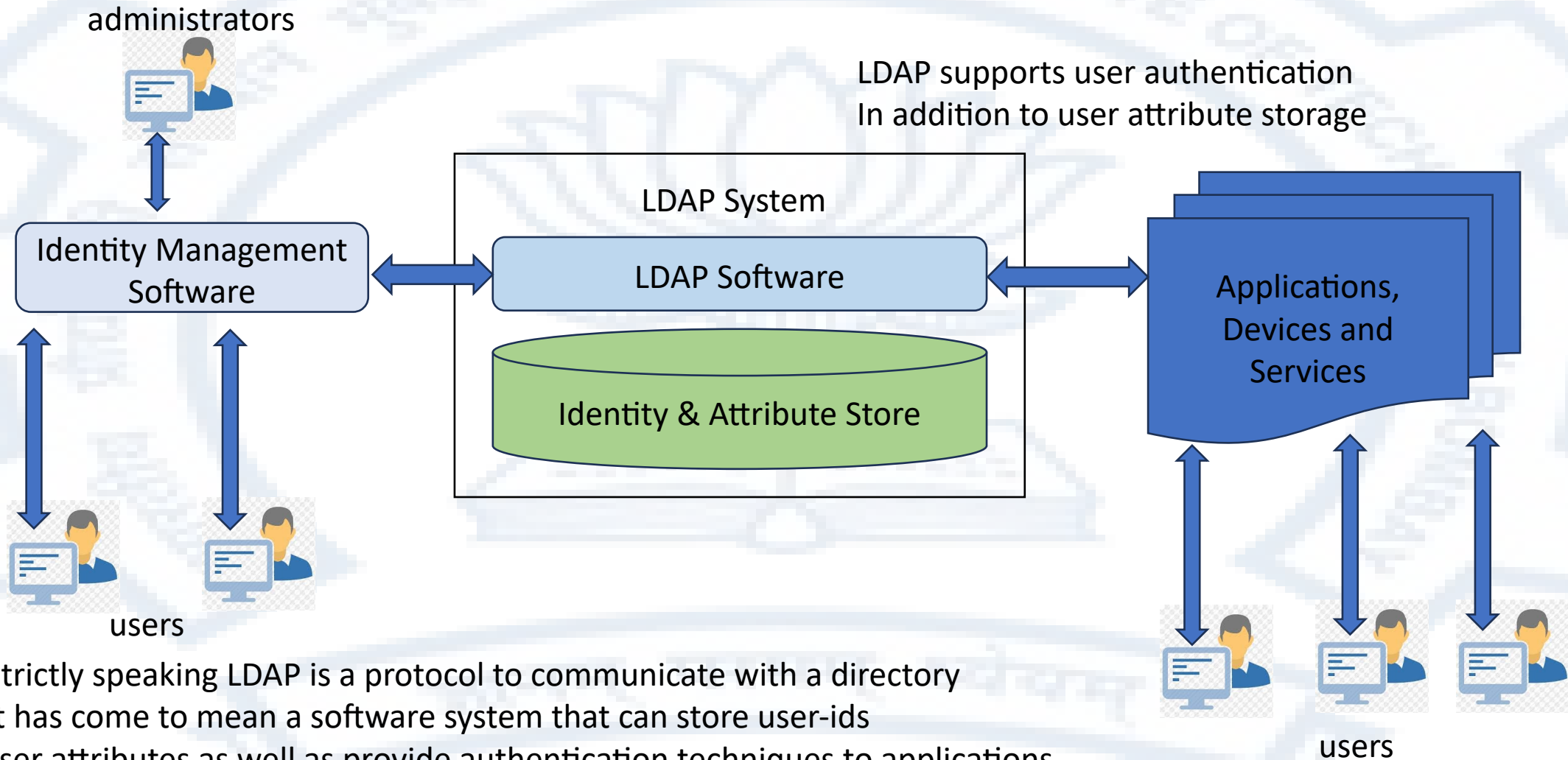
Concrete Implementation Questions

- What is a user identity?
- How is a user identity represented?
- How are access control policies associated with a user identity?
- Where is the user identity and its associated access control policies stored?
- For applications that provide services to users
 - How do they require the user to present their identity?
 - How do they fetch the user details from where they are stored?
 - What is the method that will be used for authentication?
 - How will the access control policies that are associated with the user be enforced?
- Finally, what is the assurance that this whole system will work as designed and expected?

The early days

- Multiuser operating systems had their own special files where user-ids and their passwords were stored. In the earliest days the passwords were stored in the clear. In unix like systems this will most commonly be /etc/passwd
- This user identity and password were only used to grant access to the operating system
- Each application had its own user-id and password which it stored in its own specific way
- As organizations began to develop and use many applications, the proliferation of user-ids and associated authentication information began to be seen as a problem. This motivated the idea of identity management
- In the initial days the main motivation for identity management was to reduce the cost and confusion associated with managing multiple identities in an organization

LDAP



- Strictly speaking LDAP is a protocol to communicate with a directory
- It has come to mean a software system that can store user-ids user attributes as well as provide authentication techniques to applications

Single Sign On (SSO)- an example

Computer Center
IIT Bombay



Sign in with LDAP

IITB LDAP Password

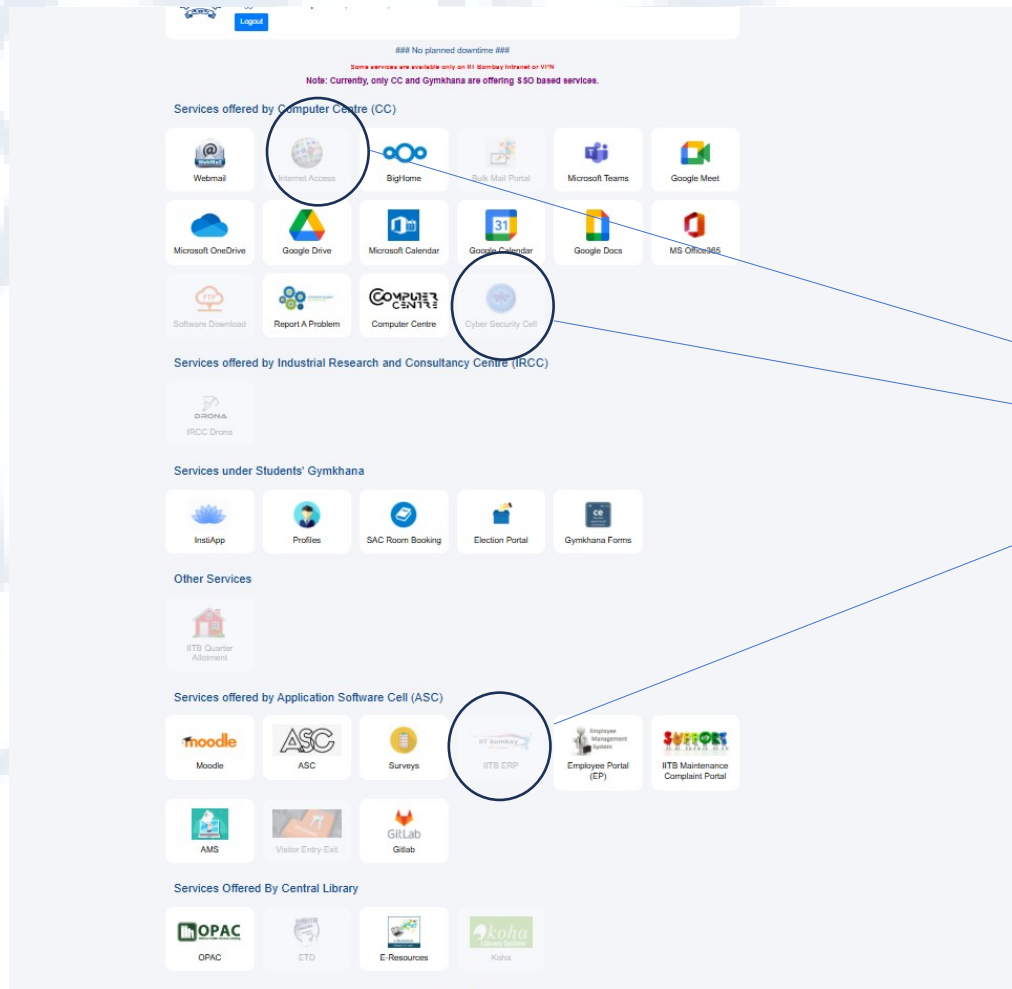
OTP

Enter the OTP from your registered authenticator app

☐ Remember me on this device

Login

The Enterprise Portal – an example



Some applications are not available if you access the portal over the Internet and not from within the organizational network

Individual Applications behind an SSO facade

2025-01-01 13:34:14

Home | Sign in |

- Academic
- Library/Archives
- Placement
- Moodle
- IRCC
- Admin Interfaces
- Surveys
- Maintenance complaints
- GatePass
- Guest House
- Visitor Entry/Exit Pass
- Downloadable Forms
- Online Purchase System (Reports Only)
- Scrutiny of job applicants
- Online Mobile Registry
- Print

Welcome to the IITB Academics and Administrative Portal

View all ERP notices

LDAP User ID
Password

Login

New Roll Number Syntax from 2022
SOP for SolMan_End User and SOP for SolMan_Ticket Processor
SOP for DMS and Approval of DMS document
ERP Refresher workshop (Presentations_Recordings_Aug_Sep_2021)
ASC-ERP Helpdesk details
ERP Login to view salary slip & Apply/Approve leave
Approving document which is not available as work-item in SAP inbox
Multifunding Purchase Process Purchase committee formation rules
ERP Manuals: Logging in, Forgot password, Approval of Advance, SOP for PR-PO Approval, Approval of advance settlement and reimbursements, Approve Purchase indent, Print PO, Approve Project Advance, SRM, Purchase(MM) & Payment(FI) Manuals, Manage SAP inbox, GST related Post PO process Cost Centers Purchasing groups View long Text in PR
ERP Login for Purchase, payments and advances
Clearing SAP inbox
Introductory PPTs on ERP covering PR-PO, purchase and payment processes
Online Job requisition. SOP for HoDs
Standard Operating Procedure to apply for Compensatory off leave
Procedure for Import below 2.5 Lakh value through Direct Market Purchase
Self declaration by Foreign Visitors & Guests PR-PO Purchase of Assets (PPT PDF) PR-PO process for Non-Assets (PPT PDF)

https://erp.iitb.ac.in

"Notice: Information published at this website is owned by IIT Bombay. Any data/information downloaded from this site cannot be

Why does this application require reauthentication?

- Oversight?
- Bug?
- Some other reason?

[Home](#) | [Sign out](#) |

[+ Academic](#)

[+ Department](#)

[+ Library/Archives](#)

[APAR](#)

[E Service Book](#)

[Faculty Self-assessment](#)

[Placement](#)

[SAP user license details](#)

[ERP Master data](#)

[Accounts and Salary](#)

[Moodle](#)

[IRCC](#)

[Surveys](#)

[+ Admin Interfaces](#)

[Maintenance complaints](#)

[Visitor Entry/Exit Pass](#)

[Guest House](#)

[GatePass](#)

[+ Downloadable Forms](#)

[Online Purchase System \(Reports Only\)](#)

[Scrutiny of job applicants](#)

[Online Mobile Registry](#)

[Print](#)

IITB Academics and Administrative Portal

Welcome

[Go to My Courses and click on Course Code to get registered students for your course in PDF or to have list with photograph or sort the list.](#)

[Check registration interface for a student at ASC -> Academic -> Students -> Students Interface](#)

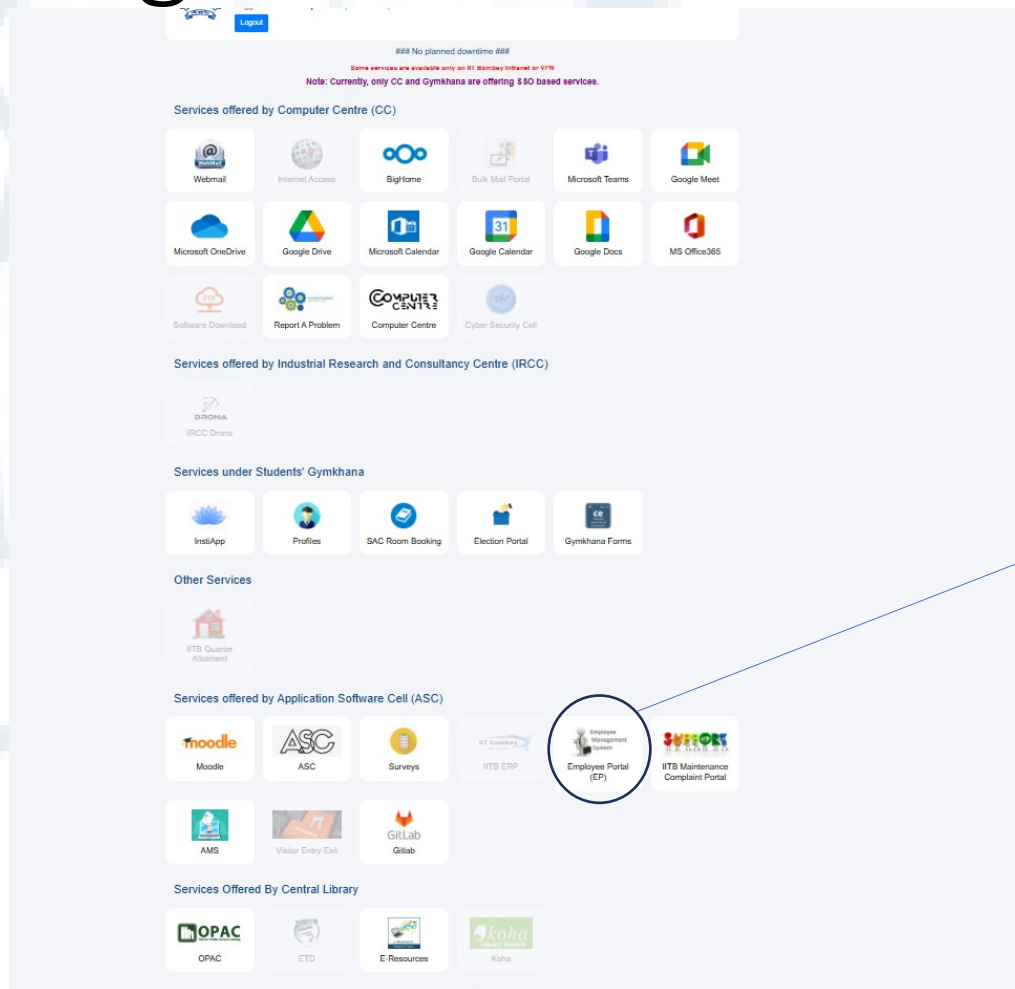
Please refer Academic Calendar at [here](#).

Please refer Academic circulars [here](#).

Many of these links will now open in the context of the specific user id and the **role (i.e. student or faculty member etc.)**

ASC

Opportunities for more comprehensive integration



Using this app requires a
Different identity



User ID *

Password *

Log On

[IITB users: Forgot password? Click here](#)

[Non IIT-B users: Forgot password? Click here](#)

[View Open Tenders](#)

Copyright © IIT Bombay. All Rights Reserved.



Federated Identity Management

Federated Identity Management is the trusting of electronic identities and the methods of authenticating them across different organizations.

An enterprise single sign on is some sort of a federated system where different applications belonging to an organization trust and use one single identity source.

The concept can be generalized to a situation where an application trusts the identities that are authenticated by some external identity provider. Examples are the use of google or twitter login by many applications to establish identity and grant access

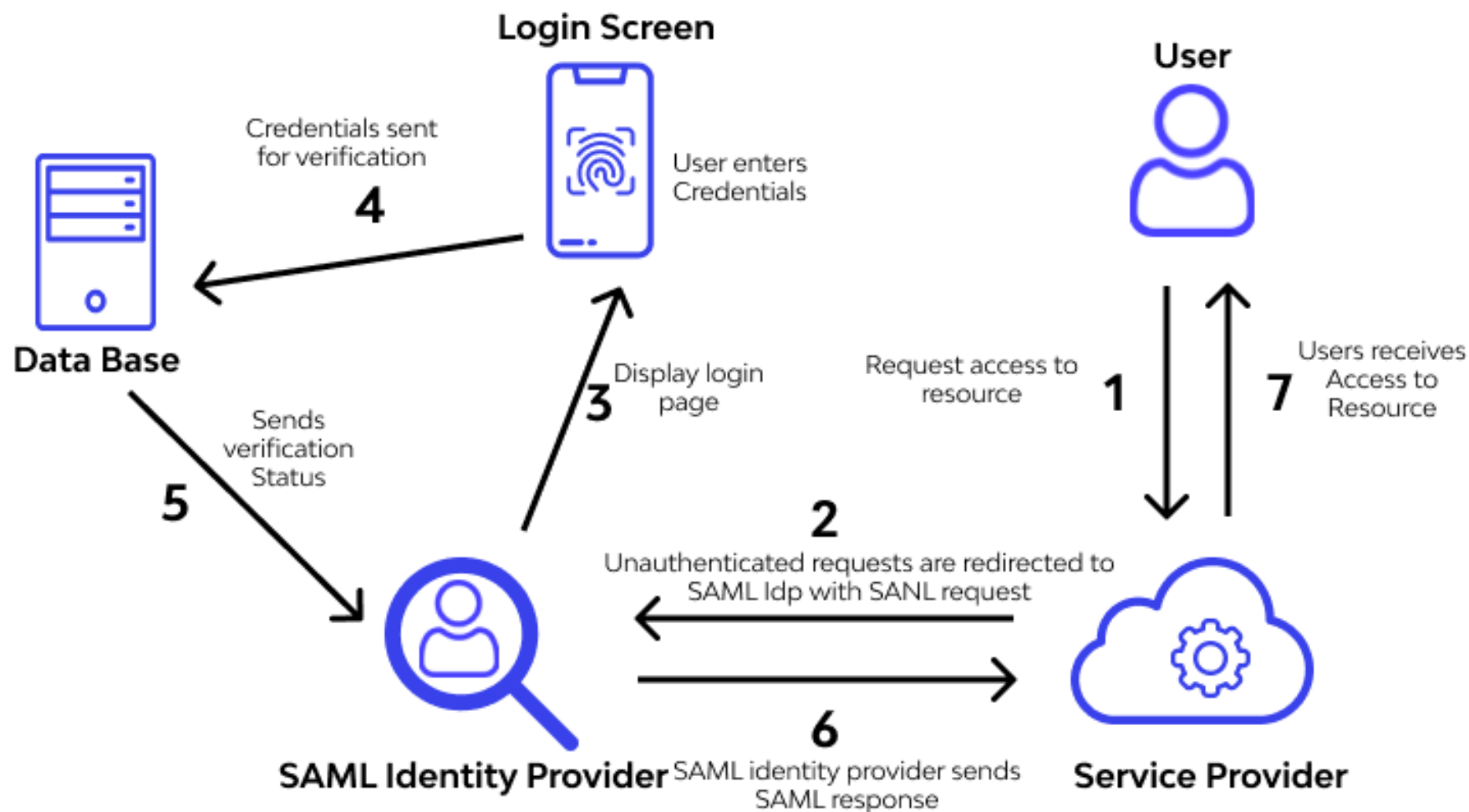
Fine grained access control

- Once a user has been authenticated and associated with a role in a centralized manner, how is this information to be passed to various applications that the user wishes to use?
 - Should a central function authenticate and then allow access to any subsequent access without further intervention?
 - Should called services validate authentication and authorization?
 - To what granularity should this validation of authentication and authorization be done?
 - How should authentication and authorization information be communicated?

SAML

- SAML stands for Security Assertion Markup Language
- It is a XML- based standard that is used to communicate identity, authentication and authorization information between different software entities
- SAML is used to convey
 - Authentication
 - Attributes of the entity authenticated
 - Authorization to grant access to requested resources

Security Assertion Markup Language (SAML) Authentication Process



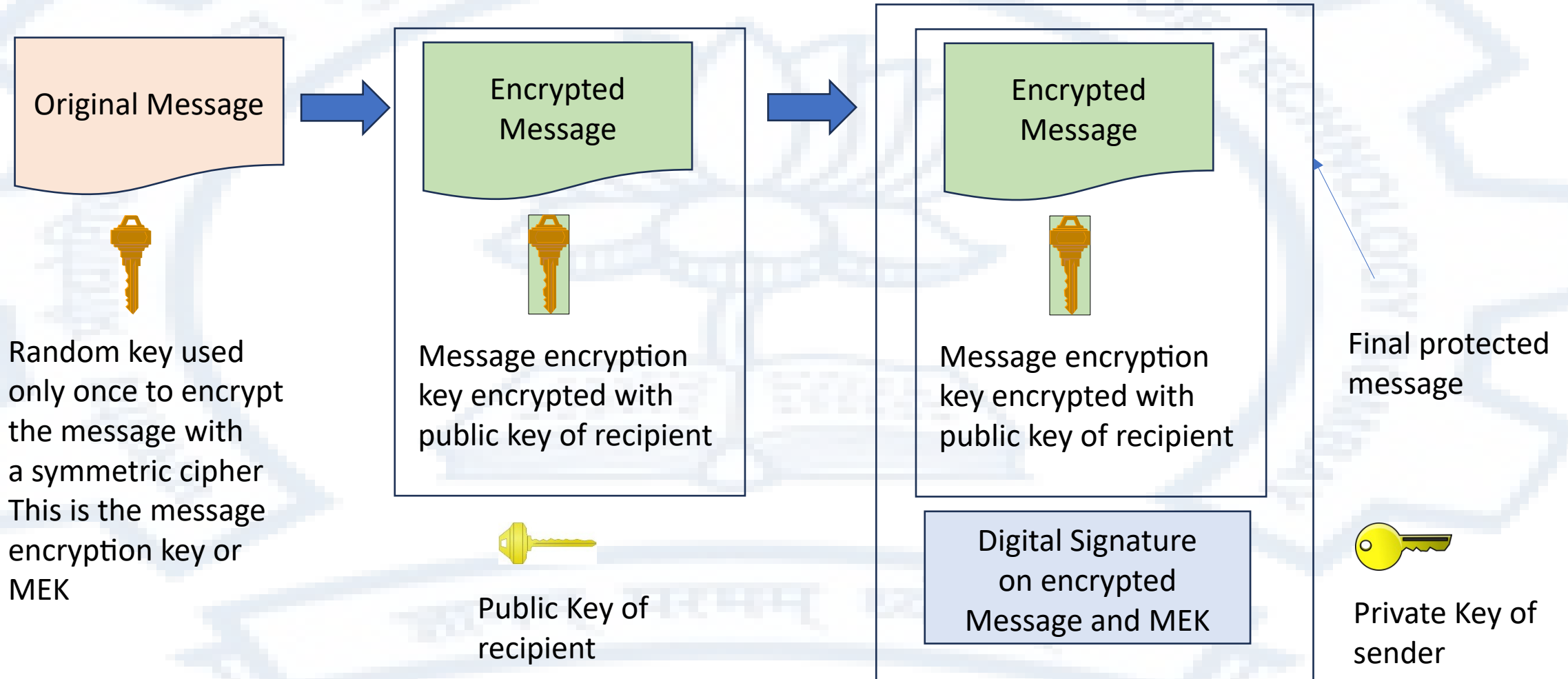
What a SAML Assertion looks like

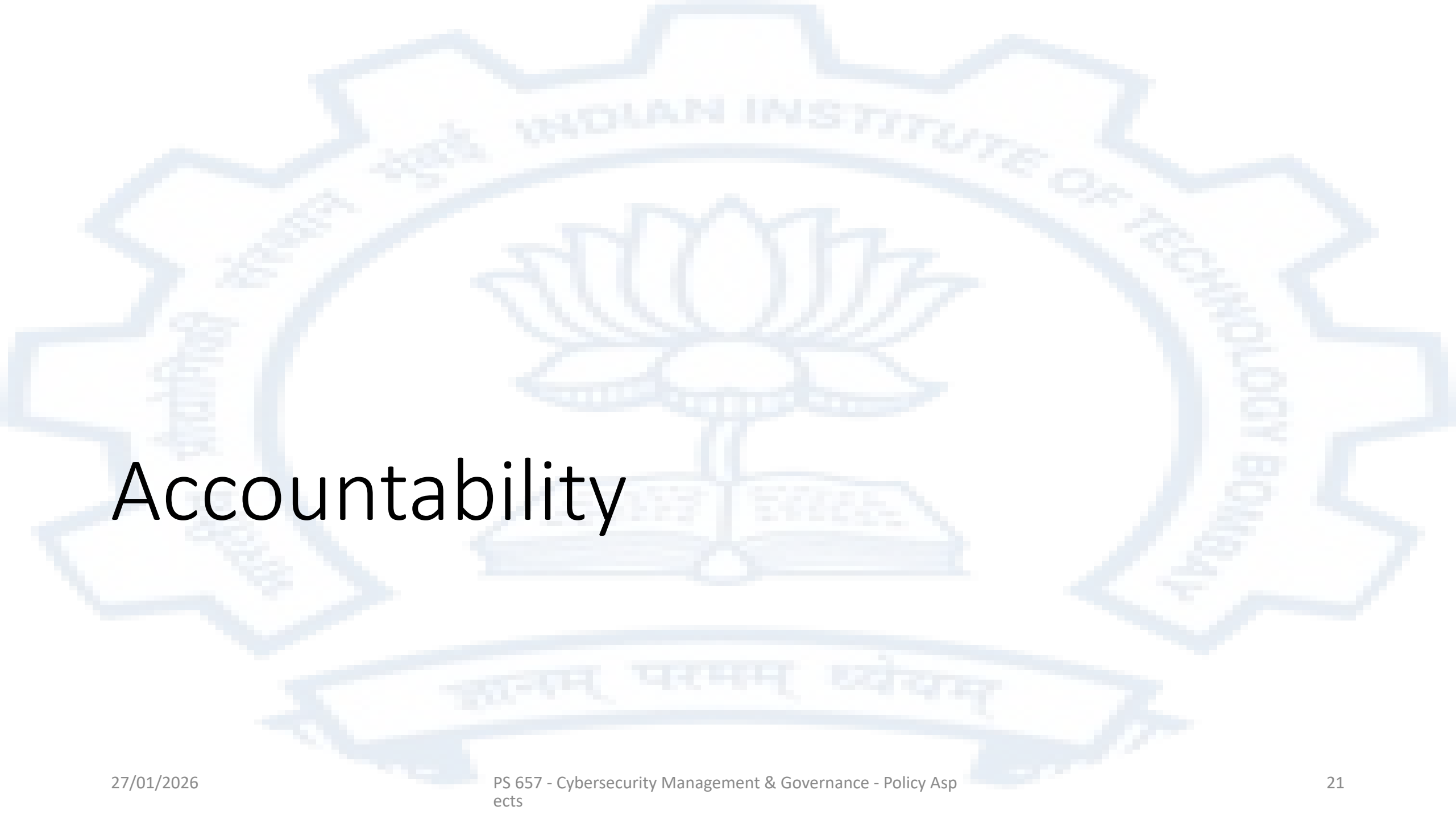
```
<saml:AuthnStatement
  AuthnInstant="2024-08-04T12:30:00Z"
  SessionIndex="_abc4567890">
  <saml:AuthnContext>
    <saml:AuthnContextClassRef>
urn:oasis:names:tc:SAML:2.0:ac:classes:PasswordProtectedTransport
    </saml:AuthnContextClassRef>
  </saml:AuthnContext>
</saml:AuthnStatement>
```

How are SAML statements secured?

- To secure a SAML statement it must be cryptographically protected. The options are
 - Sign the statement
 - Encrypt the statement
 - Encrypt and sign the statement
- What is the method of encryption and signing?
- How are the keys to be protected?

Typical message protection method



The background of the slide features a large, light blue watermark of the Indian Institute of Technology Bombay (IIT Bombay) logo. The logo is a gear-like shape with a lotus flower in the center. The text "INDIAN INSTITUTE OF TECHNOLOGY BOMBAY" is written along the top inner edge of the gear. At the bottom, there is a banner with the Sanskrit motto "सत्यम् धर्मम् विद्यया" (Satyam Dharmam Vidhyaya).

Accountability

Accountability – The Grand Challenge

For too long, our approach to information protection policy has been to seek ways to prevent information from escaping beyond appropriate boundaries, then wring our hands when it inevitably does.

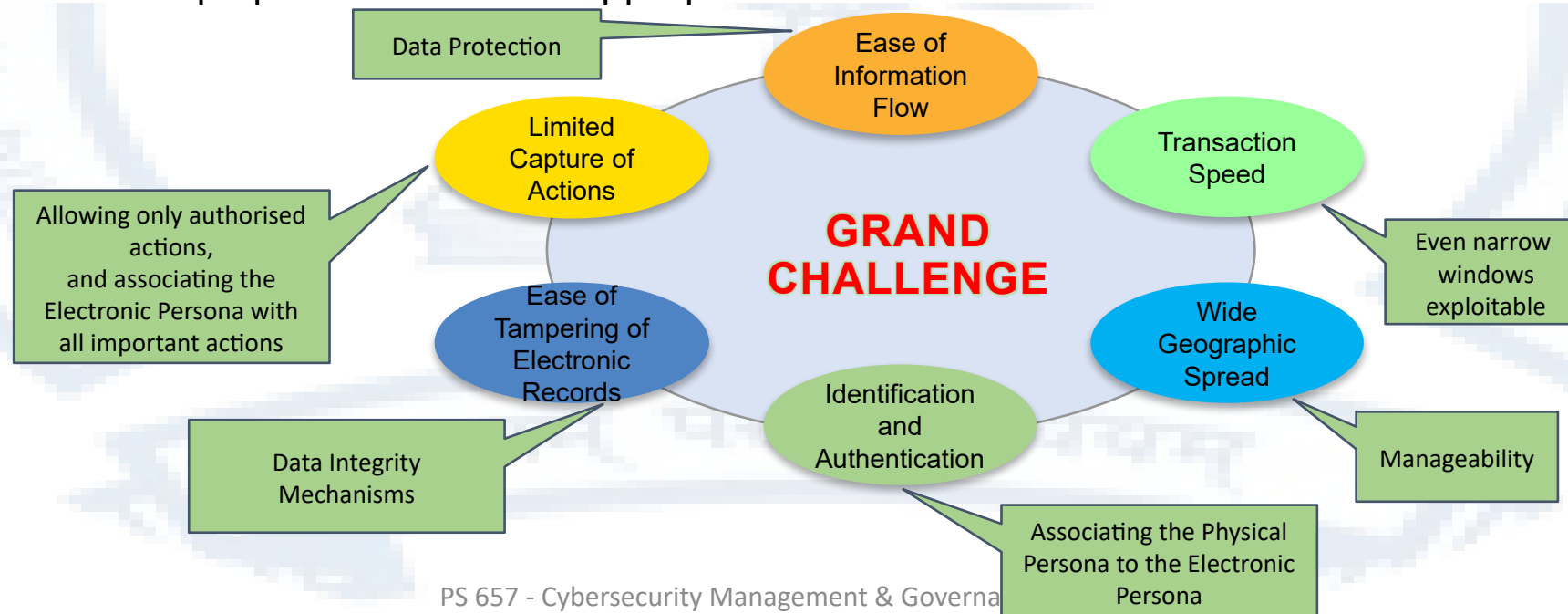
- “Information Accountability” by Weitzner, Abelson, Berners-Lee, Feigenbaum, Hendler, and Sussman

People and organizations should not have to give up the benefits of using information appropriately in powerful networked systems in order to avoid the harms that result when the same information is used inappropriately.

- Joan Feigenbaum

When information has been used, it should be possible to determine what happened, and to pinpoint use that is inappropriate.

- Daniel J. Weitzner



Accountability – A definition

“the security goal that generates the requirement for actions of an entity to be traced uniquely to that entity. This supports non-repudiation, deterrence, fault isolation, intrusion detection and prevention, and after-action recovery and legal action” – CyBOK v1.1.0

Since the definition contains deterrence and legal action, there are psychological and sociological aspects involved in addition to the technical aspects. However some key technical aspects can be identified.

Audit Policies

- Accountability requires evidence
- Evidence of actions should be available as entities in some log
- Examples of events that should be logged
 - login events (failed or successful)
 - File creation events (failed or successful)
 - File deletion events (failed or successful)
 - Memory usage alarms
 - Processor usage alarms

Distributed logging

A single end-to-end transaction, like logging onto an online bank account, selecting a payee and making a payment which is debited to the payer's account and credited to the payee's account, may involve processing by several components which may be running on more than one physical computer

Each of these components might store logs in different ways and in different locations

Standardizing logging across systems is an important task

syslog is an example of an early effort to standardize logging

Preserving Evidence

When considering evidence it is important to ensure that the evidence is not changed in any way since it was collected. Various methods to ensure this are

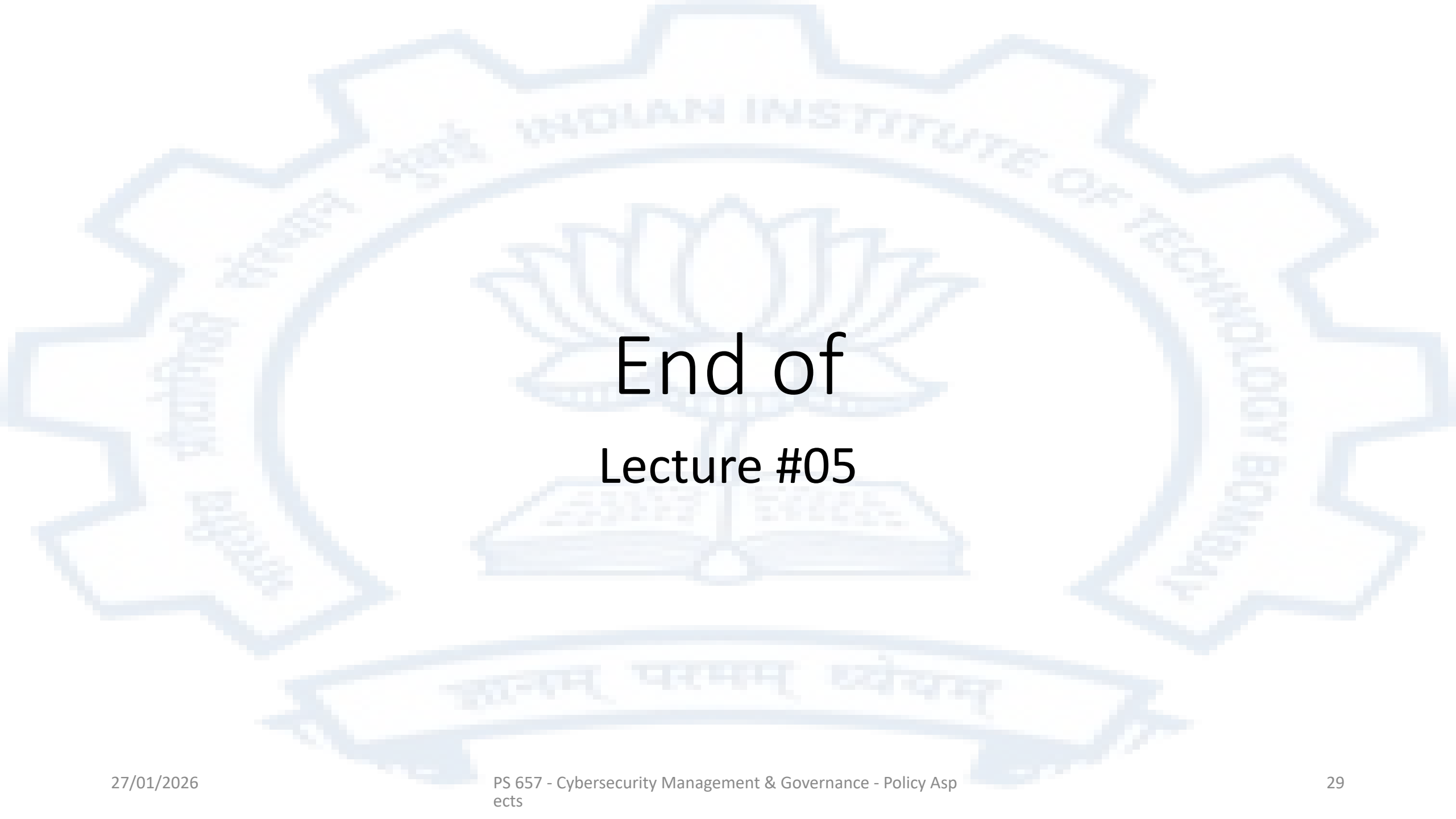
- Write to endless paper reel
- Write to WORM devices
- Use cryptographic methods like hash functions, digital signatures or block chains

Analysing Evidence

- The number of events logged can be very high
- If the logs are distributed then several locations have to be examined and events correlated
- Since distributed logging processes may be running on different processors in different time zones, time-synchronizations and capturing of the timezone are critical to the analysis
- All of the above points create a situation where manual analysis of logs is totally impractical and appropriate tools need to be used

To summarize

- Modern information systems have to deal with thousands of electronic identities of which some are human and others are software processes
- Electronic Identities have to be created, associated with privileges and destroyed when no longer needed. This whole process is called Identity Management
- The purpose of an electronic identity is to gain access to an information system and use various services and resources.
- The process of ensuring that an electronic identity only does what it is permitted to is called access management
- From the standpoint of accountability we need to ensure that our access management is working and if it fails we need to be able to determine how and why.

The background of the slide features a large, light blue watermark of the Indian Institute of Technology Bombay logo. The logo is circular with a gear-like outer border. Inside the border, the text "INDIAN INSTITUTE OF TECHNOLOGY BOMBAY" is written in a circular path. In the center of the logo is a stylized lotus flower with five petals, and below it is an open book. At the bottom of the logo, there is a banner with the Sanskrit motto "सत्यम् धर्मम् विद्यया" (Satyam Dharmam Vidhyaya).

End of Lecture #05